

D486 - Task 1 - Attempt 1

Silver Alcid - #011933973

8/18/2025

A. Summarize the gaps that currently exist in the company's security framework

The *Security Assessment Report for Fielder Medical Center (SAR)* outlines several weaknesses that need to be addressed for the organization to meet compliance requirements and improve its overall security posture. These gaps show that FMC has not kept its systems and policies up to date with federal standards, which leaves both the organization and its data at risk.

Lack of Security Controls and Policies

FMC currently lacks clear access control policies, account management processes, and enforcement of least privilege. There are also no defined rules for how security attributes should be applied to users and systems. There is no consistent way to prevent unauthorized access, which is a fundamental compliance expectation.

Outdated System Design and Security Plan

The system design and the Security System Plan (SSP) are outdated and no longer align with compliance requirements. This means that the organization is operating with a framework that does not reflect modern threats or regulatory expectations.

Deficient Security and Privacy Plans

The SAR notes that FMC has not developed a comprehensive information security program plan. There is also no updated inventory of systems or assets, and no recent risk assessment has been conducted. Without these, FMC lacks the ability to properly measure and manage risk, which prevents it from making informed choices about its security strategy.

Authentication and Access Control Weaknesses

A significant gap is the absence of multifactor authentication (MFA). Doctors who upload licensing and professional documents do not go through a secure authentication process. Because these files include personally identifiable information (PII), such as social security numbers and addresses, the lack of MFA creates a high risk of data exposure.

Endpoint Security Deficiencies

FMC's endpoint security is inconsistent and unreliable. Some workstations use unlicensed antivirus software, while others have no antivirus protection at all. This leaves the organization exposed to malware and other attacks that target endpoints.

Weaknesses in PCI DSS Preparation

The report also highlights issues with FMC's preparation for PCI DSS compliance. The planned point-of-sale (POS) system lacks critical protections, such as a properly configured firewall, the removal of vendor default credentials, and antivirus coverage. These shortcomings would prevent FMC from meeting PCI DSS requirements and could expose customer transactions to unnecessary risk.

Inadequate Data Protection for PII

Finally, FMC has not established strong safeguards for the sensitive information uploaded by doctors or accessed by government agencies. The current web portal does not enforce secure authentication, leaving sensitive records vulnerable to unauthorized access. These gaps could easily result in compliance violations and damage to FMC's reputation if not corrected.

B. Identify and justify risks and decisions

AC-6 (Least Privilege) is a high risk. At the moment, FMC allows users more access than they need to do their jobs. That opens the door for both mistake and deliberate misuse. If a single account is compromised, a large amount of sensitive data could be exposed. The data involved here is not trivial: licensing documents, addresses, even social security numbers. This control is foundational. NIST SP 800-53 make it clear that least privilege is required for federal systems ((National Institute of Standards and Technology [NIST], 2020)). Accepting the risk is not realistic because it would create both compliance failures and a genuine security hazard.

CA-5 (Plans of Action and Milestones) carries a moderate risk. The problem is simple but serious: without a structured plan, FMC has no way to show that it is tracking or resolving known issues. Vulnerabilities might be identified but then left without a timeline or accountability. That gap undermines both operational security and compliance. Regulators expect organizations to keep evidence that risks are being addressed in an orderly way. If FMC does not remediate this auditors will see an organization that identifies problems but does nothing concrete to close them. A POA&M provides a roadmap and accountability, both of which are currently missing.

CA-7 (Continuous Monitoring) is rated high risk. Without monitoring, threats can slip into the network and remain there for weeks, possibly months. For an organization that stores personally identifiable information, that is unacceptable. A lack of visibility into the system essentially means FMC is operating blind. This goes against NST requirements and against industry expectations for federally funded healthcare facilities. Continuous monitoring is not a luxury. It is the only way to maintain awareness of what is happening across the network. Choosing not to remediate here would amount to ignoring one of the most basic elements of security.

RA-3 (Risk Assessment) also falls into the high category. Without updated assessments, FMC cannot claim to understand its own threat landscape. Leaders are left making decisions without the evidence they need. NIST guidance stresses that risk assessments must be conducted on a recurring basis (National Institute of Standards and Technology [NIST], 2020). They identify vulnerabilities, weigh their likelihood, and measure potential impact. FMC has none of this at present. The result is guesswork. If this control is not remediated, the organization will remain exposed while also failing compliance checks. Regular assessments are not just paperwork; they are the groundwork for every other security measure.

RA-7 (Risk Response) is considered moderate. While it may not seem as urgent as the others, the lack of a defined process for responding to risks creates confusion. Decisions about whether to mitigate or accept risks could be made inconsistently. They might not be documented at all. That kind of ad hoc approach undermines governance. Regulators expect organizations to demonstrate why certain risks were accepted and how others were addressed. FMC has no way to do that right now. Remediating this control would provide consistency and clarity. Leaving it alone would create uncertainty and weaken the organization's credibility.

C. Risk Remediation

AC-6 (Least Privilege):

FMC should adopt role-based access control so users only have the permissions needed for their specific responsibilities. Regular reviews of user accounts should be scheduled to confirm access is still appropriate, and unnecessary privileges should be revoked quickly. Technical enforcement, like automated account provisioning tools, will help ensure consistency.

CA-5 (Plans of Action and Milestones):

A formal POA&M process must be developed to document every identified risk, assign responsibility, and set deadlines. This process should include a central tracking system or risk management tool where progress can be monitored and reported. Regular reviews by leadership will keep remediation on track and maintain accountability.

CA-7 (Continuous Monitoring):

FMC should implement continuous monitoring tools such as intrusion detection and prevention systems, log analysis solutions, and endpoint detection platforms. These should generate real-time alerts tied to defined escalation procedures. Automation can assist, but dedicated staff must review alerts and respond promptly to incidents.

RA-3 (Risk Assessment):

FMC needs to conduct a comprehensive risk assessment following NIST SP 800-30. This assessment must document threats, vulnerabilities, and potential impacts, then rank them by likelihood and severity. The process should be repeated regularly, at least annually, and whenever significant changes occur in the IT environment.

RA-7 (Risk Response):

A structured risk response framework should be created to guide decisions on whether to mitigate, transfer, or accept risks. Each decision must be documented in a risk register, along with the justification. This ensures consistency, transparency, and compliance while providing evidence to auditors that risks are being managed deliberately.

C. PCI DSS-Compliant Policy

Firewall Configuration and Vendor Default Removal

Policy: FMC will implement and maintain a properly configured firewall for all network segments connected to the point-of-sale (POS) system. All vendor-supplied default passwords and configurations must be replaced before deployment.

Roles and Responsibilities:

- IT Security Administrator: Responsible for firewall setup, secure configuration, and periodic reviews.
- System Administrators: Ensure default credentials are changed on all devices and documented securely.

Antivirus and Endpoint Protection

Policy: All workstations, servers, and POS devices must run licensed, regularly updated antivirus software. The antivirus solution must be centrally managed and monitored to ensure consistent protection across FMC systems.

Roles and Responsibilities:

- IT Operations Team: Deploy and maintain antivirus solutions across all devices, verify updates are applied, and ensure logs are monitored.
- CISO: Review reports and confirm endpoint security compliance during quarterly audits.

Secure Authentication for Doctor Web Portal

Policy: Multifactor authentication (MFA) will be required for all doctor logins to the FMC portal. The authentication process must protect uploaded documents containing personally identifiable information (PII) from unauthorized access.

Roles and Responsibilities:

- CISO: Define MFA requirements and enforce compliance with PCI DSS authentication standards.
- IT Security Team: Implement and manage MFA solutions, provide support for users, and conduct regular testing of authentication controls

References

National Institute of Standards and Technology. (2020). *Security and Privacy Controls for Information Systems and Organizations (NIST SP 800-53, Rev. 5)*.